Burp Scanner Report

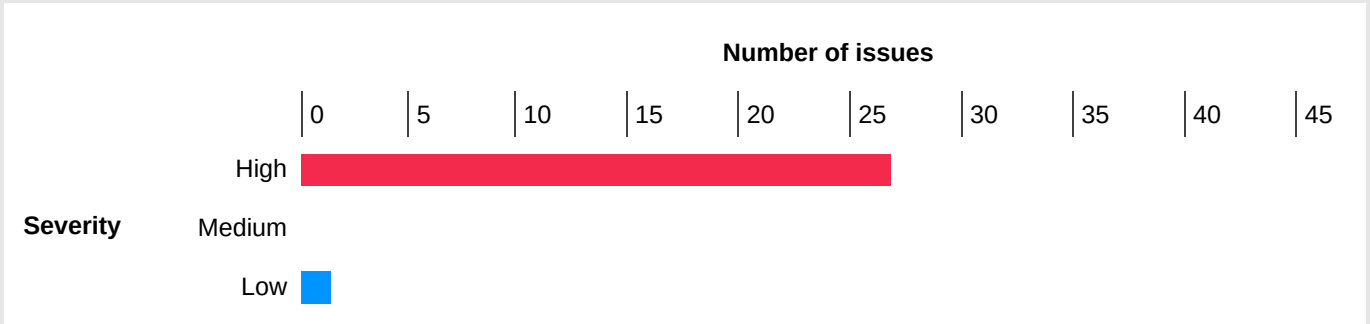
Burp Suite Professional

Summary

The table below shows the numbers of issues identified in different categories. Issues are classified according to severity as High, Medium, Low, Information or False Positive. This reflects the likely impact of each issue for a typical organization. Issues are also classified according to confidence as Certain, Firm or Tentative. This reflects the inherent reliability of the technique that was used to identify the issue.

		Confidence			
		Certain	Firm	Tentative	Total
Severity	High	20	0	0	20
	Medium	0	0	0	0
	Low	1	0	0	1
	Information	40	1	2	43
	False Positive	0	0	0	0

The chart below shows the aggregated numbers of issues identified in each category. Solid colored bars represent issues with a confidence level of Certain, and the bars fade as the confidence level falls.



Contents

1. Cross-origin resource sharing: arbitrary origin trusted

1.1. http://10.185.200.36:8089/wp-json/
1.2. http://10.185.200.36:8089/wp-json/oembed/1.0/embed
1.3. http://10.185.200.36:8089/wp-json/tribe/events/v1/
1.4. http://10.185.200.36:8089/wp-json/wp/v2/pages/14
1.5. http://10.185.200.36:8089/wp-json/wp/v2/pages/16
1.6. http://10.185.200.36:8089/wp-json/wp/v2/pages/22
1.7. http://10.185.200.36:8089/wp-json/wp/v2/pages/24
1.8. http://10.185.200.36:8089/wp-json/wp/v2/pages/26
1.9. http://10.185.200.36:8089/wp-json/wp/v2/pages/28
1.10. http://10.185.200.36:8089/wp-json/wp/v2/pages/434
1.11. http://10.185.200.36:8089/wp-json/wp/v2/pages/458
1.12. http://10.185.200.36:8089/wp-json/wp/v2/pages/470
1.13. http://10.185.200.36:8089/wp-json/wp/v2/pages/482

1.14. http://10.185.200.36:8089/wp-json/wp/v2/pages/538
1.15. http://10.185.200.36:8089/wp-json/wp/v2/pages/543
1.16. http://10.185.200.36:8089/wp-json/wp/v2/pages/548
1.17. http://10.185.200.36:8089/wp-json/wp/v2/pages/553
1.18. http://10.185.200.36:8089/wp-json/wp/v2/pages/557
1.19. http://10.185.200.36:8089/wp-json/wp/v2/pages/562

2. Cleartext submission of password

3. Unencrypted communications

4. Content security policy: allows untrusted script execution

5. Content security policy: allows untrusted style execution

6. Content security policy: allows form hijacking

7. Cross-origin resource sharing

7.1. http://10.185.200.36:8089/wp-json/
7.2. http://10.185.200.36:8089/wp-json/oembed/1.0/embed
7.3. http://10.185.200.36:8089/wp-json/tribe/events/v1/
7.4. http://10.185.200.36:8089/wp-json/wp/v2/pages/14
7.5. http://10.185.200.36:8089/wp-json/wp/v2/pages/16
7.6. http://10.185.200.36:8089/wp-json/wp/v2/pages/22
7.7. http://10.185.200.36:8089/wp-json/wp/v2/pages/24
7.8. http://10.185.200.36:8089/wp-json/wp/v2/pages/26
7.9. http://10.185.200.36:8089/wp-json/wp/v2/pages/28
7.10. http://10.185.200.36:8089/wp-json/wp/v2/pages/434
7.11. http://10.185.200.36:8089/wp-json/wp/v2/pages/458
7.12. http://10.185.200.36:8089/wp-json/wp/v2/pages/470
7.13. http://10.185.200.36:8089/wp-json/wp/v2/pages/482
7.14. http://10.185.200.36:8089/wp-json/wp/v2/pages/538
7.15. http://10.185.200.36:8089/wp-json/wp/v2/pages/543
7.16. http://10.185.200.36:8089/wp-json/wp/v2/pages/548
7.17. http://10.185.200.36:8089/wp-json/wp/v2/pages/553
7.18. http://10.185.200.36:8089/wp-json/wp/v2/pages/557
7.19. http://10.185.200.36:8089/wp-json/wp/v2/pages/562

8. Cross-site request forgery

9. External service interaction (DNS)

10. Spoofable client IP address

11. Input returned in response (reflected)

11.1. http://10.185.200.36:8089/comments/feed/ [name of an arbitrarily supplied URL parameter]
11.2. http://10.185.200.36:8089/feed/ [name of an arbitrarily supplied URL parameter]
11.3. http://10.185.200.36:8089/wp-admin/ [name of an arbitrarily supplied URL parameter]
11.4. http://10.185.200.36:8089/wp-login.php [log parameter]
11.5. http://10.185.200.36:8089/wp-login.php [redirect_to parameter]
11.6. http://10.185.200.36:8089/wp-login.php [redirect_to parameter]
11.7. http://10.185.200.36:8089/wp-login.php [user_login parameter]

12. Cross-domain Referer leakage

13. Frameable response (potential Clickjacking)

14. Backup file

14.1. http://10.185.200.36:8089/academics~
14.2. http://10.185.200.36:8089/author/25m1522~
14.3. http://10.185.200.36:8089/langtech~

14.4. http://10.185.200.36:8089/news~
14.5. http://10.185.200.36:8089/watermgmt~

15. Email addresses disclosed

15.1. http://10.185.200.36:8089/people/
15.2. http://10.185.200.36:8089/wp-json/wp/v2/pages/16

16. Private IP addresses disclosed

17. Robots.txt file

---

1. Cross-origin resource sharing: arbitrary origin trusted

There are 19 instances of this issue:

- /wp-json/
- /wp-json/oembed/1.0/embed
- /wp-json/tribe/events/v1/
- /wp-json/wp/v2/pages/14
- /wp-json/wp/v2/pages/16
- /wp-json/wp/v2/pages/22
- /wp-json/wp/v2/pages/24
- /wp-json/wp/v2/pages/26
- /wp-json/wp/v2/pages/28
- /wp-json/wp/v2/pages/434
- /wp-json/wp/v2/pages/458
- /wp-json/wp/v2/pages/470
- /wp-json/wp/v2/pages/482
- /wp-json/wp/v2/pages/538
- /wp-json/wp/v2/pages/543
- /wp-json/wp/v2/pages/548
- /wp-json/wp/v2/pages/553
- /wp-json/wp/v2/pages/557
- /wp-json/wp/v2/pages/562

Issue background

An HTML5 cross-origin resource sharing (CORS) policy controls whether and how content running on other domains can perform two-way interaction with the domain that publishes the policy. The policy is fine-grained and can apply access controls per-request based on the URL and other features of the request.

Trusting arbitrary origins effectively disables the same-origin policy, allowing two-way interaction by third-party web sites. Unless the response consists only of unprotected public content, this policy is likely to present a security risk.

If the site specifies the header Access-Control-Allow-Credentials: true, third-party sites may be able to carry out privileged actions and retrieve sensitive information. Even if it does not, attackers may be able to bypass any IP-based access controls by proxying through users' browsers.

Issue remediation

Rather than using a wildcard or programmatically verifying supplied origins, use a whitelist of trusted domains.

References

- Web Security Academy: Cross-origin resource sharing (CORS)
- Exploiting CORS Misconfigurations

Vulnerability classifications

- CWE-942: Overly Permissive Cross-domain Whitelist

1.1. http://10.185.200.36:8089/wp-json/

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://dzfnzljynxkx.com**

Request

```
GET /wp-json/ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
Origin: http://dzfnzljynxkx.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:44 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
```

```
Access-Control-Allow-Origin: http://dzfnzljynxkx.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 389014

{"name":"Centre For Traditional Indian Knowledge and Skills","description":"","url":"http:\/
\/10.185.200.36:8089","home":"http:\/\/10.185.200.36:8089","gmt_offset":"0","timezone_string":"","page_for_p
...[SNIP]...
```

1.2. http://10.185.200.36:8089/wp-json/oembed/1.0/embed

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/oembed/1.0/embed**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://trypownyohig.com**

Request

```
GET /wp-json/oembed/1.0/embed?url=http%3A%2F%2F10.185.200.36%3A8089%2F HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
Origin: http://trypownyohig.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:26 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
```

```
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://trypownyohig.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 2194
Connection: close
Content-Type: application/json; charset=UTF-8

{"version":"1.0","provider_name":"Centre For Traditional Indian Knowledge and Skills","provider_url":"http:\/
\/10.185.200.36:8089","author_name":"Ishaan Mane","author_url":"http:\/\/10.185.200.36:8089
...[SNIP]...
```

1.3. http://10.185.200.36:8089/wp-json/tribe/events/v1/

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/tribe/events/v1/**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://ryyudykanruv.com**

Request

```
GET /wp-json/tribe/events/v1/ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
Origin: http://ryyudykanruv.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:48 GMT
```

```
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://ryyudykanruv.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 29721

{"namespace":"tribe\/events\/v1","routes":{"\/tribe\/events\/v1":{"namespace":"tribe\/events\/v1","methods":
["GET"],"endpoints":[{"methods":["GET"],"args":{"namespace":{"default":"tribe\/events\/v1","
...[SNIP]...
```

1.4. http://10.185.200.36:8089/wp-json/wp/v2/pages/14

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/14**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://juvferncwbrt.com**

Request

```
GET /wp-json/wp/v2/pages/14 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/about-us/
Origin: http://juvferncwbrt.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:58 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/about-us/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://juvferncwbrt.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 9328

{"id":14,"date":"2026-02-09T04:49:48","date_gmt":"2026-02-09T04:49:48","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=14"},"modified":"2026-03-06T05:15:49","modified_gmt":"2026-03-06T05:15:49","s
...[SNIP]...
```

1.5. http://10.185.200.36:8089/wp-json/wp/v2/pages/16

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/16**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://qbrgwdnhwacj.com**

Request

```
GET /wp-json/wp/v2/pages/16 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
```

```
Referer: http://10.185.200.36:8089/people/
Origin: http://qbrgwdnhwacj.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:59 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/people/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://qbrgwdnhwacj.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 8114

{"id":16,"date":"2026-02-09T04:50:22","date_gmt":"2026-02-09T04:50:22","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=16"},"modified":"2026-03-06T05:20:08","modified_gmt":"2026-03-06T05:20:08","s
...[SNIP]...
```

1.6. http://10.185.200.36:8089/wp-json/wp/v2/pages/22

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/22**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://ibndrbchevtq.com**

Request

```
GET /wp-json/wp/v2/pages/22 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
```

```
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/contact-us/
Origin: http://ibndrbchevtq.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:03 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/contact-us/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://ibndrbchevtq.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 4150
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":22,"date":"2026-02-09T04:51:13","date_gmt":"2026-02-09T04:51:13","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=22"},"modified":"2026-03-02T08:44:19","modified_gmt":"2026-03-02T08:44:19","s
...[SNIP]...
```

1.7. http://10.185.200.36:8089/wp-json/wp/v2/pages/24

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/24**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://klwlluozowbi.com**

Request

```
GET /wp-json/wp/v2/pages/24 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
```

```
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
Origin: http://klwlluozowbi.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:01 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://klwlluozowbi.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 21779

{"id":24,"date":"2026-02-09T04:51:38","date_gmt":"2026-02-09T04:51:38","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=24"},"modified":"2026-03-04T11:46:44","modified_gmt":"2026-03-04T11:46:44","s
...[SNIP]...
```

1.8. http://10.185.200.36:8089/wp-json/wp/v2/pages/26

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/26**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://tcsbpapynmjk.com**

Request

```
GET /wp-json/wp/v2/pages/26 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
```

```
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/research/
Origin: http://tcsbpapynmjk.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:59 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/research/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://tcsbpapynmjk.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 5156
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":26,"date":"2026-02-09T04:52:26","date_gmt":"2026-02-09T04:52:26","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=26"},"modified":"2026-03-04T11:53:38","modified_gmt":"2026-03-04T11:53:38","s
...[SNIP]...
```

1.9. http://10.185.200.36:8089/wp-json/wp/v2/pages/28

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/28**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://bamkzhwftfsh.com**

Request

```
GET /wp-json/wp/v2/pages/28 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/academics/
Origin: http://bamkzhwftfsh.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:58 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/academics/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://bamkzhwftfsh.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 2859
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":28,"date":"2026-02-09T04:52:53","date_gmt":"2026-02-09T04:52:53","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=28"},"modified":"2026-03-02T08:47:38","modified_gmt":"2026-03-02T08:47:38","s
...[SNIP]...
```

1.10. http://10.185.200.36:8089/wp-json/wp/v2/pages/434

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/434**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://mgsnsmpsixmc.com**

Request

```
GET /wp-json/wp/v2/pages/434 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/phd_adm/
Origin: http://mgsnsmpsixmc.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:07 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/phd_adm/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://mgsnsmpsixmc.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 10020

{"id":434,"date":"2026-03-02T08:25:35","date_gmt":"2026-03-02T08:25:35","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=434"},"modified":"2026-03-02T14:59:51","modified_gmt":"2026-03-02T14:59:51",
...[SNIP]...
```

1.11. http://10.185.200.36:8089/wp-json/wp/v2/pages/458

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/458**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://evviclgytssl.com**

Request

```
GET /wp-json/wp/v2/pages/458 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/news/
Origin: http://evviclgytssl.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:03 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/news/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://evviclgytssl.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 5785
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":458,"date":"2026-03-02T08:48:01","date_gmt":"2026-03-02T08:48:01","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=458"},"modified":"2026-03-02T10:11:05","modified_gmt":"2026-03-02T10:11:05",
...[SNIP]...
```

1.12. http://10.185.200.36:8089/wp-json/wp/v2/pages/470

Summary

Severity:	**High**
Confidence:	**Certain**

Host: **http://10.185.200.36:8089**

Path: **/wp-json/wp/v2/pages/470**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://fgfjtnjdsnkq.com**

Request

```
GET /wp-json/wp/v2/pages/470 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/announcements/
Origin: http://fgfjtnjdsnkq.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:03 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/announcements/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://fgfjtnjdsnkq.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 8188

{"id":470,"date":"2026-03-02T09:10:17","date_gmt":"2026-03-02T09:10:17","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=470"},"modified":"2026-03-02T09:10:38","modified_gmt":"2026-03-02T09:10:38",
...[SNIP]...
```

1.13. http://10.185.200.36:8089/wp-json/wp/v2/pages/482

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/482**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://ldgrxkobjjmx.com**

Request

```
GET /wp-json/wp/v2/pages/482 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/eventspage/
Origin: http://ldgrxkobjjmx.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:03 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/eventspage/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://ldgrxkobjjmx.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 3611
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":482,"date":"2026-03-02T09:17:58","date_gmt":"2026-03-02T09:17:58","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=482"},"modified":"2026-03-02T10:16:20","modified_gmt":"2026-03-02T10:16:20",
...[SNIP]...
```

1.14. http://10.185.200.36:8089/wp-json/wp/v2/pages/538

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/538**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://dkgztkofekmu.com**

Request

```
GET /wp-json/wp/v2/pages/538 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/astromaths/
Origin: http://dkgztkofekmu.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:05 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/astromaths/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://dkgztkofekmu.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 3370
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":538,"date":"2026-03-02T14:02:09","date_gmt":"2026-03-02T14:02:09","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=538"},"modified":"2026-03-02T14:04:37","modified_gmt":"2026-03-02T14:04:37",
...[SNIP]...
```

1.15. http://10.185.200.36:8089/wp-json/wp/v2/pages/543

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/543**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://mdwjvhjziash.com**

Request

```
GET /wp-json/wp/v2/pages/543 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/langtech/
Origin: http://mdwjvhjziash.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:05 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/langtech/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://mdwjvhjziash.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 3320
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":543,"date":"2026-03-02T14:05:34","date_gmt":"2026-03-02T14:05:34","guid":{"rendered":"http:\/\/10.18.33.196\/?
```

page_id=543"},"modified":"2026-03-02T14:06:42","modified_gmt":"2026-03-02T14:06:42",
...[SNIP]...

1.16. http://10.185.200.36:8089/wp-json/wp/v2/pages/548

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/548**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://zfwzzkalahou.com**

Request

```
GET /wp-json/wp/v2/pages/548 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/yoga/
Origin: http://zfwzzkalahou.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:03 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/yoga/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://zfwzzkalahou.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 3266
```

```
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":548,"date":"2026-03-02T14:07:21","date_gmt":"2026-03-02T14:07:21","guid":{"rendered":"http:\/\/10.18.33.196\/?page_id=548"},"modified":"2026-03-02T14:09:38","modified_gmt":"2026-03-02T14:09:38",
...[SNIP]...
```

1.17. http://10.185.200.36:8089/wp-json/wp/v2/pages/553

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/553**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://ecebbvmerffp.com**

Request

```
GET /wp-json/wp/v2/pages/553 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/watermgmt/
Origin: http://ecebbvmerffp.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:06 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/watermgmt/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://ecebbvmerffp.com
```

```
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 3492
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":553,"date":"2026-03-02T14:11:19","date_gmt":"2026-03-02T14:11:19","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=553"},"modified":"2026-03-02T14:24:52","modified_gmt":"2026-03-02T14:24:52",
...[SNIP]...
```

1.18. http://10.185.200.36:8089/wp-json/wp/v2/pages/557

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/557**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://hftqwcldopjz.com**

Request

```
GET /wp-json/wp/v2/pages/557 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/heritage/
Origin: http://hftqwcldopjz.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:04 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/heritage/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
```

```
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://hftqwcldopjz.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 2985
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":557,"date":"2026-03-02T14:14:49","date_gmt":"2026-03-02T14:14:49","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=557"},"modified":"2026-03-02T14:16:35","modified_gmt":"2026-03-02T14:16:35",
...[SNIP]...
```

1.19. http://10.185.200.36:8089/wp-json/wp/v2/pages/562

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/562**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **http://dmnhbvsyvdon.com**

Request

```
GET /wp-json/wp/v2/pages/562 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/indianbusiness/
Origin: http://dmnhbvsyvdon.com
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:05 GMT
Server: Apache/2.4.66 (Debian)
```

```
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/indianbusiness/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://dmnhbvsyvdon.com
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 3563
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":562,"date":"2026-03-02T14:17:50","date_gmt":"2026-03-02T14:17:50","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=562"},"modified":"2026-03-02T14:19:15","modified_gmt":"2026-03-02T14:19:15",
...[SNIP]...
```

2. Cleartext submission of password

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-login.php**

Issue detail

The page contains a form with the following action URL, which is submitted over clear-text HTTP:

- http://10.185.200.36:8089/wp-login.php

The form contains the following password field:

- pwd

Issue background

Some applications transmit passwords over unencrypted connections, making them vulnerable to interception. To exploit this vulnerability, an attacker must be suitably positioned to eavesdrop on the victim's network traffic. This scenario typically occurs when a client communicates with the server over an insecure connection such as public Wi-Fi, or a corporate or home network that is shared with a compromised computer. Common defenses such as switched networks are not sufficient to prevent this. An attacker situated in the user's ISP or the application's hosting infrastructure could also perform this attack. Note that an advanced adversary could potentially target any connection made over the Internet's core infrastructure.

Vulnerabilities that result in the disclosure of users' passwords can result in compromises that are extremely difficult to investigate due to obscured audit trails. Even if the application itself only handles non-sensitive information, exposing passwords puts users who have re-used their password elsewhere at risk.

Issue remediation

Applications should use transport-level encryption (SSL or TLS) to protect all sensitive communications passing between the client and the server. Communications that should be protected include the login mechanism and related functionality, and any functions where sensitive data can be accessed or privileged actions can be performed. These areas should employ their own session handling mechanism, and the session tokens used should never be transmitted over unencrypted communications. If HTTP cookies are used for transmitting session tokens, then the secure flag should be set to prevent

transmission over clear-text HTTP.

Vulnerability classifications

- CWE-319: Cleartext Transmission of Sensitive Information
- CAPEC-117: Interception

Request

```
POST /wp-login.php HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/wp-login.php?redirect_to=http%3A%2F%2F10.185.200.36%3A8089%2Fwp-
admin%2F&reauth=1
Content-Type: application/x-www-form-urlencoded
Content-Length: 140
Cookie: wordpress_test_cookie=WP%20Cookie%20check

log=zQeUjLgS&pwd=I5F%21m2n%21F9&rememberme=forever&wp-
submit=Log+In&redirect_to=http%3a%2f%2f10.185.200.36%3a8089%2fwp-admin%2f&testcookie=1
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:11 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self';
Referrer-Policy: strict-origin-when-cross-origin
Vary: Accept-Encoding
Content-Length: 8997
Connection: close
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
  <html lang="en-US">
  <head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Log In &lsaquo; Centre For Traditional Indian Knowledge and Skills &#8212; W
...[SNIP]...
</div>
    <form name="loginform" id="loginform" action="http://10.185.200.36:8089/wp-login.php" method="post">
        <p>
...[SNIP]...
<div class="wp-pwd">
                <input type="password" name="pwd" id="user_pass" aria-describedby="login_error" class="input password-
input" value="" size="20" autocomplete="current-password" spellcheck="false" required="required" />
                <button type="button" class="button button-secondary wp-hide-pw hide-if-no-js" data-toggle="0" aria-
```

```
label="Show password">
...[SNIP]...
```

3. Unencrypted communications

Summary

Severity:	**Low**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/**

Issue description

The application allows users to connect to it over unencrypted connections. An attacker suitably positioned to view a legitimate user's network traffic could record and monitor their interactions with the application and obtain any information the user supplies. Furthermore, an attacker able to modify traffic could use the application as a platform for attacks against its users and third-party websites. Unencrypted connections have been exploited by ISPs and governments to track users, and to inject adverts and malicious JavaScript. Due to these concerns, web browser vendors are planning to visually flag unencrypted connections as hazardous.

To exploit this vulnerability, an attacker must be suitably positioned to eavesdrop on the victim's network traffic. This scenario typically occurs when a client communicates with the server over an insecure connection such as public Wi-Fi, or a corporate or home network that is shared with a compromised computer. Common defenses such as switched networks are not sufficient to prevent this. An attacker situated in the user's ISP or the application's hosting infrastructure could also perform this attack. Note that an advanced adversary could potentially target any connection made over the Internet's core infrastructure.

Please note that using a mixture of encrypted and unencrypted communications is an ineffective defense against active attackers, because they can easily remove references to encrypted resources when these references are transmitted over an unencrypted connection.

Issue remediation

Applications should use transport-level encryption (SSL/TLS) to protect all communications passing between the client and the server. The Strict-Transport-Security HTTP header should be used to ensure that clients refuse to access the server over an insecure connection.

References

- Marking HTTP as non-secure
- Configuring Server-Side SSL/TLS
- HTTP Strict Transport Security

Vulnerability classifications

- CWE-326: Inadequate Encryption Strength
- CAPEC-94: Man in the Middle Attack
- CAPEC-157: Sniffing Attacks

4. Content security policy: allows untrusted script execution

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-login.php**

Issue detail

The content security policy fails to prevent untrusted JavaScript from being executed. As a result, it may fail to mitigate cross-site scripting attacks.

The policy has the following issues:

The policy allows global wildcard URLs which allows arbitrary scripts to be executed.

The policy allows data: URLs which allows arbitrary scripts to be executed.

Issue background

Content Security Policy (CSP) is a security mechanism designed to mitigate cross-site scripting attacks by disabling dangerous behaviours such as untrusted JavaScript execution. Websites can specify their security policy in a response header or meta tag, enabling fine-grained control over dangerous features like scripts and stylesheets.

Issue remediation

Mitigate cross-site scripting by avoiding 'unsafe-inline', 'unsafe-eval', data: URLs, and global wildcards in script directives. Use a secure, random nonce of at least 8 characters 'nonce-RANDOM' to prevent untrusted JavaScript execution.

References

- Web Security Academy: What is CSP?
- Web Security Academy: What is XSS?
- Web Security Academy: Mitigating XSS attacks using CSP
- Web Security Academy: Preventing XSS
- Content Security Policy (CSP)

Vulnerability classifications

- CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
- CWE-80: Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)
- CWE-116: Improper Encoding or Escaping of Output
- CWE-159: Failure to Sanitize Special Element
- CAPEC-588: DOM-Based XSS

Request

```
POST /wp-login.php HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
```

```
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/wp-login.php?redirect_to=http%3A%2F%2F10.185.200.36%3A8089%2Fwp-admin%2F&reauth=1
Content-Type: application/x-www-form-urlencoded
Content-Length: 140
Cookie: wordpress_test_cookie=WP%20Cookie%20check

log=zQeUjLgS&pwd=I5F%21m2n%21F9&rememberme=forever&wp-submit=Log+In&redirect_to=http%3a%2f%2f10.185.200.36%3a8089%2fwp-admin%2f&testcookie=1
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:11 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self';
Referrer-Policy: strict-origin-when-cross-origin
Vary: Accept-Encoding
Content-Length: 8997
Connection: close
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
  <html lang="en-US">
  <head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Log In &lsaquo; Centre For Traditional Indian Knowledge and Skills &#8212; W
...[SNIP]...
```

---

5. Content security policy: allows untrusted style execution

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-login.php**

Issue detail

The content security policy fails to prevent untrusted style execution. As a result, it may fail to mitigate style based data exfiltration.

The policy allows global wildcard URLs which allows arbitrary styles to be executed.

The policy allows data: URLs which allows arbitrary styles to be executed.

Issue background

Content Security Policy (CSP) is a security mechanism designed to mitigate cross-site scripting attacks by disabling dangerous behaviours such as untrusted JavaScript execution. Websites can specify their security policy in a response

header or meta tag, enabling fine-grained control over dangerous features like scripts and stylesheets.

Issue remediation

Mitigate style-based data exfiltration by avoiding 'unsafe-inline', data: URLs, and global wildcards in style directives. Use a secure, random nonce of at least 8 characters 'nonce-RANDOM' in the relevant directive.

References

- Web Security Academy: What is CSP?
- PortSwigger Research: Blind CSS exfiltration
- PortSwigger Research: Offensive CSS research
- Content Security Policy (CSP)

Vulnerability classifications

- CWE-116: Improper Encoding or Escaping of Output
- CWE-159: Failure to Sanitize Special Element
- CAPEC-468: Generic Cross-Browser Cross-Domain Theft

Request

```
POST /wp-login.php HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/wp-login.php?redirect_to=http%3A%2F%2F10.185.200.36%3A8089%2Fwp-
admin%2F&reauth=1
Content-Type: application/x-www-form-urlencoded
Content-Length: 140
Cookie: wordpress_test_cookie=WP%20Cookie%20check

log=zQeUjLgS&pwd=I5F%21m2n%21F9&rememberme=forever&wp-
submit=Log+In&redirect_to=http%3a%2f%2f10.185.200.36%3a8089%2fwp-admin%2f&testcookie=1
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:11 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self';
Referrer-Policy: strict-origin-when-cross-origin
Vary: Accept-Encoding
Content-Length: 8997
Connection: close
Content-Type: text/html; charset=UTF-8
```

```
<!DOCTYPE html>
  <html lang="en-US">
  <head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Log In &lsaquo; Centre For Traditional Indian Knowledge and Skills &#8212; W
...[SNIP]...
```

6. Content security policy: allows form hijacking

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-login.php**

Issue detail

The content security policy doesn't prevent form hijacking, where attackers with HTML injection hijack forms using action attributes. This can lead to credential theft by autofilling passwords from a manager and sending them to an attacker's server upon form submission.

Issue background

Content Security Policy (CSP) is a security mechanism designed to mitigate cross-site scripting attacks by disabling dangerous behaviours such as untrusted JavaScript execution. Websites can specify their security policy in a response header or meta tag, enabling fine-grained control over dangerous features like scripts and stylesheets.

Issue remediation

We recommend using the form-action directive in the CSP response header to control form post destinations. If no form actions are used, set form-action to 'none' to block untrusted forms. For applications without external form URLs, use 'self' to allow only same-origin URLs. If needed, allow list hosts for external URL form submissions, but be aware this lets attackers submit to these external resources.

References

- PortSwigger Research: Stealing passwords from infosec Mastodon - without bypassing CSP
- Web Security Academy: What is CSP?
- Content Security Policy (CSP)

Vulnerability classifications

- CWE-116: Improper Encoding or Escaping of Output

Request

```
POST /wp-login.php HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
```

```
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/wp-login.php?redirect_to=http%3A%2F%2F10.185.200.36%3A8089%2Fwp-admin%2F&reauth=1
Content-Type: application/x-www-form-urlencoded
Content-Length: 140
Cookie: wordpress_test_cookie=WP%20Cookie%20check

log=zQeUjLgS&pwd=I5F%21m2n%21F9&rememberme=forever&wp-submit=Log+In&redirect_to=http%3a%2f%2f10.185.200.36%3a8089%2fwp-admin%2f&testcookie=1
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:11 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self';
Referrer-Policy: strict-origin-when-cross-origin
Vary: Accept-Encoding
Content-Length: 8997
Connection: close
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
  <html lang="en-US">
  <head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Log In &lsaquo; Centre For Traditional Indian Knowledge and Skills &#8212; W
...[SNIP]...
```

---

7. Cross-origin resource sharing

There are 19 instances of this issue:

- /wp-json/
- /wp-json/oembed/1.0/embed
- /wp-json/tribe/events/v1/
- /wp-json/wp/v2/pages/14
- /wp-json/wp/v2/pages/16
- /wp-json/wp/v2/pages/22
- /wp-json/wp/v2/pages/24
- /wp-json/wp/v2/pages/26
- /wp-json/wp/v2/pages/28
- /wp-json/wp/v2/pages/434
- /wp-json/wp/v2/pages/458
- /wp-json/wp/v2/pages/470
- /wp-json/wp/v2/pages/482
- /wp-json/wp/v2/pages/538
- /wp-json/wp/v2/pages/543
- /wp-json/wp/v2/pages/548
- /wp-json/wp/v2/pages/553

- /wp-json/wp/v2/pages/557
- /wp-json/wp/v2/pages/562

Issue background

An HTML5 cross-origin resource sharing (CORS) policy controls whether and how content running on other domains can perform two-way interaction with the domain that publishes the policy. The policy is fine-grained and can apply access controls per-request based on the URL and other features of the request.

If another domain is allowed by the policy, then that domain can potentially attack users of the application. If a user is logged in to the application, and visits a domain allowed by the policy, then any malicious content running on that domain can potentially retrieve content from the application, and sometimes carry out actions within the security context of the logged in user.

Even if an allowed domain is not overtly malicious in itself, security vulnerabilities within that domain could potentially be leveraged by an attacker to exploit the trust relationship and attack the application that allows access. CORS policies on pages containing sensitive information should be reviewed to determine whether it is appropriate for the application to trust both the intentions and security posture of any domains granted access.

Issue remediation

Any inappropriate domains should be removed from the CORS policy.

References

- Web Security Academy: Cross-origin resource sharing (CORS)
- Exploiting CORS Misconfigurations

Vulnerability classifications

- CWE-942: Overly Permissive Cross-domain Whitelist

7.1. http://10.185.200.36:8089/wp-json/

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
```

```
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:44 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 389014

{"name":"Centre For Traditional Indian Knowledge and Skills","description":"","url":"http:\/
\/10.185.200.36:8089","home":"http:\/\/10.185.200.36:8089","gmt_offset":"0","timezone_string":"","page_for_p
...[SNIP]...
```

7.2. http://10.185.200.36:8089/wp-json/oembed/1.0/embed

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/oembed/1.0/embed**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/oembed/1.0/embed?url=http%3A%2F%2F10.185.200.36%3A8089%2F HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
```

```
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:26 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 2194
Connection: close
Content-Type: application/json; charset=UTF-8

{"version":"1.0","provider_name":"Centre For Traditional Indian Knowledge and Skills","provider_url":"http:\/
\/10.185.200.36:8089","author_name":"Ishaan Mane","author_url":"http:\/\/10.185.200.36:8089
...[SNIP]...
```

7.3. http://10.185.200.36:8089/wp-json/tribe/events/v1/

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/tribe/events/v1/**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/tribe/events/v1/ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
```

```
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:48 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 29721

{"namespace":"tribe\/events\/v1","routes":{"\/tribe\/events\/v1":{"namespace":"tribe\/events\/v1","methods":
["GET"],"endpoints":[{"methods":["GET"],"args":{"namespace":{"default":"tribe\/events\/v1","
...[SNIP]...
```

7.4. http://10.185.200.36:8089/wp-json/wp/v2/pages/14

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/14**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/14 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
```

```
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/about-us/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:58 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/about-us/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 9328

{"id":14,"date":"2026-02-09T04:49:48","date_gmt":"2026-02-09T04:49:48","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=14"},"modified":"2026-03-06T05:15:49","modified_gmt":"2026-03-06T05:15:49","s
...[SNIP]...
```

7.5. http://10.185.200.36:8089/wp-json/wp/v2/pages/16

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/16**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/16 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
```

```
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/people/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:58 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/people/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 8114

{"id":16,"date":"2026-02-09T04:50:22","date_gmt":"2026-02-09T04:50:22","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=16"},"modified":"2026-03-06T05:20:08","modified_gmt":"2026-03-06T05:20:08","s
...[SNIP]...
```

7.6. http://10.185.200.36:8089/wp-json/wp/v2/pages/22

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/22**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/22 HTTP/1.1
Host: 10.185.200.36:8089
```

```
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/contact-us/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:03 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/contact-us/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 4150
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":22,"date":"2026-02-09T04:51:13","date_gmt":"2026-02-09T04:51:13","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=22"},"modified":"2026-03-02T08:44:19","modified_gmt":"2026-03-02T08:44:19","s
...[SNIP]...
```

7.7. http://10.185.200.36:8089/wp-json/wp/v2/pages/24

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/24**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/24 HTTP/1.1
```

```
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:01 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 21779

{"id":24,"date":"2026-02-09T04:51:38","date_gmt":"2026-02-09T04:51:38","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=24"},"modified":"2026-03-04T11:46:44","modified_gmt":"2026-03-04T11:46:44","s
...[SNIP]...
```

7.8. http://10.185.200.36:8089/wp-json/wp/v2/pages/26

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/26**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/26 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/research/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:59 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/research/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 5156
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":26,"date":"2026-02-09T04:52:26","date_gmt":"2026-02-09T04:52:26","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=26"},"modified":"2026-03-04T11:53:38","modified_gmt":"2026-03-04T11:53:38","s
...[SNIP]...
```

7.9. http://10.185.200.36:8089/wp-json/wp/v2/pages/28

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/28**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/28 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/academics/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:58 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/academics/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 2859
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":28,"date":"2026-02-09T04:52:53","date_gmt":"2026-02-09T04:52:53","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=28"},"modified":"2026-03-02T08:47:38","modified_gmt":"2026-03-02T08:47:38","s
...[SNIP]...
```

7.10. http://10.185.200.36:8089/wp-json/wp/v2/pages/434

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/434**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/434 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/phd_adm/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:06 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/phd_adm/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 10020

{"id":434,"date":"2026-03-02T08:25:35","date_gmt":"2026-03-02T08:25:35","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=434"},"modified":"2026-03-02T14:59:51","modified_gmt":"2026-03-02T14:59:51",
...[SNIP]...
```

7.11. http://10.185.200.36:8089/wp-json/wp/v2/pages/458

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/458**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/458 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/news/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:03 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/news/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 5785
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":458,"date":"2026-03-02T08:48:01","date_gmt":"2026-03-02T08:48:01","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=458"},"modified":"2026-03-02T10:11:05","modified_gmt":"2026-03-02T10:11:05",
...[SNIP]...
```

7.12. http://10.185.200.36:8089/wp-json/wp/v2/pages/470

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/470**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/470 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/announcements/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:03 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/announcements/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 8188

{"id":470,"date":"2026-03-02T09:10:17","date_gmt":"2026-03-02T09:10:17","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=470"},"modified":"2026-03-02T09:10:38","modified_gmt":"2026-03-02T09:10:38",
...[SNIP]...
```

7.13. http://10.185.200.36:8089/wp-json/wp/v2/pages/482

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/482**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/482 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/eventspage/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:03 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/eventspage/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 3611
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":482,"date":"2026-03-02T09:17:58","date_gmt":"2026-03-02T09:17:58","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=482"},"modified":"2026-03-02T10:16:20","modified_gmt":"2026-03-02T10:16:20",
...[SNIP]...
```

7.14. http://10.185.200.36:8089/wp-json/wp/v2/pages/538

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/538**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/538 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/astromaths/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:05 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/astromaths/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 3370
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":538,"date":"2026-03-02T14:02:09","date_gmt":"2026-03-02T14:02:09","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=538"},"modified":"2026-03-02T14:04:37","modified_gmt":"2026-03-02T14:04:37",
...[SNIP]...
```

7.15. http://10.185.200.36:8089/wp-json/wp/v2/pages/543

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/543**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/543 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/langtech/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:05 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/langtech/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 3320
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":543,"date":"2026-03-02T14:05:34","date_gmt":"2026-03-02T14:05:34","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=543"},"modified":"2026-03-02T14:06:42","modified_gmt":"2026-03-02T14:06:42",
...[SNIP]...
```

7.16. http://10.185.200.36:8089/wp-json/wp/v2/pages/548

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/548**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/548 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/yoga/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:03 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/yoga/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 3266
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":548,"date":"2026-03-02T14:07:21","date_gmt":"2026-03-02T14:07:21","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=548"},"modified":"2026-03-02T14:09:38","modified_gmt":"2026-03-02T14:09:38",
...[SNIP]...
```

7.17. http://10.185.200.36:8089/wp-json/wp/v2/pages/553

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/553**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/553 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/watermgmt/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:06 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/watermgmt/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 3492
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":553,"date":"2026-03-02T14:11:19","date_gmt":"2026-03-02T14:11:19","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=553"},"modified":"2026-03-02T14:24:52","modified_gmt":"2026-03-02T14:24:52",
...[SNIP]...
```

7.18. http://10.185.200.36:8089/wp-json/wp/v2/pages/557

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/557**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/557 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/heritage/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:04 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/heritage/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 2985
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":557,"date":"2026-03-02T14:14:49","date_gmt":"2026-03-02T14:14:49","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=557"},"modified":"2026-03-02T14:16:35","modified_gmt":"2026-03-02T14:16:35",
...[SNIP]...
```

7.19. http://10.185.200.36:8089/wp-json/wp/v2/pages/562

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/562**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request.

Request

```
GET /wp-json/wp/v2/pages/562 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/indianbusiness/
Origin: http://10.185.200.36:8089
```

Response

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:22:05 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/indianbusiness/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Access-Control-Allow-Origin: http://10.185.200.36:8089
Access-Control-Allow-Methods: OPTIONS, GET, POST, PUT, PATCH, DELETE
Access-Control-Allow-Credentials: true
Vary: Origin
Content-Length: 3563
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":562,"date":"2026-03-02T14:17:50","date_gmt":"2026-03-02T14:17:50","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=562"},"modified":"2026-03-02T14:19:15","modified_gmt":"2026-03-02T14:19:15",
...[SNIP]...
```

---

8. Cross-site request forgery

Summary

Severity:	**Information**
Confidence:	**Tentative**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-login.php**

Issue detail

The request appears to be vulnerable to cross-site request forgery (CSRF) attacks against unauthenticated functionality. This is unlikely to constitute a security vulnerability in its own right, however it may facilitate exploitation of other vulnerabilities affecting application users.

Issue background

Cross-site request forgery (CSRF) vulnerabilities may arise when applications rely solely on HTTP cookies to identify the user that has issued a particular request. Because browsers automatically add cookies to requests regardless of their origin, it may be possible for an attacker to create a malicious web site that forges a cross-domain request to the vulnerable application. For a request to be vulnerable to CSRF, the following conditions must hold:

- The request can be issued cross-domain, for example using an HTML form. If the request contains non-standard headers or body content, then it may only be issuable from a page that originated on the same domain.
- The application relies solely on HTTP cookies or Basic Authentication to identify the user that issued the request. If the application places session-related tokens elsewhere within the request, then it may not be vulnerable.
- The request performs some privileged action within the application, which modifies the application's state based on the identity of the issuing user.
- The attacker can determine all the parameters required to construct a request that performs the action. If the request contains any values that the attacker cannot determine or predict, then it is not vulnerable.

Issue remediation

The most effective way to protect against CSRF vulnerabilities is to include within relevant requests an additional token that is not transmitted in a cookie: for example, a parameter in a hidden form field. This additional token should contain sufficient entropy, and be generated using a cryptographic random number generator, such that it is not feasible for an attacker to determine or predict the value of any token that was issued to another user. The token should be associated with the user's session, and the application should validate that the correct token is received before performing any action resulting from the request.

An alternative approach, which may be easier to implement, is to validate that Host and Referer headers in relevant requests are both present and contain the same domain name. However, this approach is somewhat less robust: historically, quirks in browsers and plugins have often enabled attackers to forge cross-domain requests that manipulate these headers to bypass such defenses.

References

- Web Security Academy: Cross-site request forgery
- Using Burp to Test for Cross-Site Request Forgery
- The Deputies Are Still Confused

Vulnerability classifications

- CWE-352: Cross-Site Request Forgery (CSRF)
- CAPEC-62: Cross Site Request Forgery

Request 1

```
POST /wp-login.php?action=lostpassword HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/wp-login.php?action=lostpassword
Content-Type: application/x-www-form-urlencoded
```

```
Content-Length: 11
Cookie: wordpress_test_cookie=WP%20Cookie%20check

user_login=
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:21 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self';
Referrer-Policy: strict-origin-when-cross-origin
Vary: Accept-Encoding
Content-Length: 5607
Connection: close
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
  <html lang="en-US">
  <head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Lost Password &lsaquo; Centre For Traditional Indian Knowledge and Skills &#
...[SNIP]...
```

Request 2

```
POST /wp-login.php?action=lostpassword HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://rLmTHxDWB.com:8089/wp-login.php?action=lostpassword
Content-Type: application/x-www-form-urlencoded
Content-Length: 11
Cookie: wordpress_test_cookie=WP%20Cookie%20check

user_login=
```

Response 2

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:02 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
```

```
Content-Security-Policy: frame-ancestors 'self';
Referrer-Policy: strict-origin-when-cross-origin
Vary: Accept-Encoding
Content-Length: 5607
Connection: close
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
  <html lang="en-US">
  <head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Lost Password &lsaquo; Centre For Traditional Indian Knowledge and Skills &#
...[SNIP]...
```

9. External service interaction (DNS)

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/**

Issue detail

It is possible to induce the application to perform server-side DNS lookups of arbitrary domain names.

The payload **uhfdmckflyz8a73qfyx9sqgy5pbiz8n1fp5cv0k.oastify.com** was submitted in the HTTP X-Forwarded-For header.

The application performed a DNS lookup of the specified domain.

Issue background

The ability to induce an application to interact with an arbitrary external service, such as a web or mail server, does not constitute a vulnerability in its own right. This might even be the intended behavior of the application. However, in some cases, it can indicate a vulnerability with serious consequences.

If you can trigger DNS-based interactions, it is normally possible to trigger interactions using other service types. Burp Scanner reports these as separate issues. You may find that a payload, such as a URL, only triggers a DNS-based interaction, even though you were expecting interactions with a different service as well. This could be due to egress filters on the network layer that prevent the application from connecting to these other services. However, some systems perform DNS lookups without any intention of connecting to the remote host. This behavior is typically harmless.

The ability to send requests to other systems can allow the vulnerable server to be used as an attack proxy. By submitting suitable payloads, an attacker can cause the application server to attack other systems that it can interact with. This may include public third-party systems, internal systems within the same organization, or services available on the local loopback adapter of the application server itself. Depending on the network architecture, this may expose highly vulnerable internal services that are not otherwise accessible to external attackers.

Issue remediation

You should review the purpose and intended use of the relevant application functionality, and determine whether the ability to trigger arbitrary external service interactions is intended behavior. If so, you should be aware of the types of attacks that can be performed via this behavior and take appropriate measures. These measures might include blocking network access from the application server to other internal systems, and hardening the application server itself to remove any services available on the local loopback adapter.

If the ability to trigger arbitrary external service interactions is not intended behavior, then you should implement a whitelist

of permitted services and hosts, and block any interactions that do not appear on this whitelist.

Out-of-Band Application Security Testing (OAST) is highly effective at uncovering high-risk features, to the point where finding the root cause of an interaction can be quite challenging. To find the source of an external service interaction, try to identify whether it is triggered by specific application functionality, or occurs indiscriminately on all requests. If it occurs on all endpoints, a front-end CDN or application firewall may be responsible, or a back-end analytics system parsing server logs. In some cases, interactions may originate from third-party systems; for example, a HTTP request may trigger a poisoned email which passes through a link-scanner on its way to the recipient.

References

- Burp Collaborator
- Out-of-band application security testing (OAST)
- PortSwigger Research: Cracking the Lens

Vulnerability classifications

- CWE-918: Server-Side Request Forgery (SSRF)
- CWE-406: Insufficient Control of Network Message Volume (Network Amplification)

Request 1

```
GET / HTTP/1.1
Host: 10.185.200.36:8089
X-Forwarded-For: uhfdmckflyz8a73qfyx9sqgy5pbiz8n1fp5cv0k.oastify.com
Pragma: no-cache
Cache-Control: no-cache, no-transform
Connection: close
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:44 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
Link: <http://10.185.200.36:8089/wp-json/wp/v2/pages/24>; rel="alternate"; title="JSON"; type="application/json"
Link: <http://10.185.200.36:8089/>; rel=shortlink
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Vary: Accept-Encoding
Connection: close
Content-Type: text/html; charset=UTF-8
Content-Length: 91313

<!doctype html>
<html lang="en-US">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1">
<link rel="profile" href="https://gmpg.org/xfn/11">

...[SNIP]...
```

Collaborator DNS interaction

The Collaborator server received a DNS lookup of type A for the domain name **uhfdmckflyz8a73qfyx9sqgy5pbiz8n1fp5cv0k.oastify.com**.

The lookup was received from IP address 103.21.127.65:28869 at 2026-Mar-11 06:20:46.053 UTC.

---

10. Spoofable client IP address

Summary

Severity:	**Information**
Confidence:	**Tentative**
Host:	**http://10.185.200.36:8089**
Path:	**/**

Issue detail

It may be possible for clients to spoof their IP address using the X-Forwarded-For HTTP header.

The payload **oqi7v6t9us82j1ckos631kpsejkc82wvujk6auz.oastify.com** was submitted in the X-Forwarded-For HTTP header.

The application resolved the supplied domain name, indicating that it is reading and processing this header.

However, when multiple domains are specified the application interacts with all of them. This means there is a chance the header is being rewritten by an intermediate server, and the application isn't actually vulnerable to IP address spoofing.

Issue background

If an application trusts an HTTP request header like X-Forwarded-For to accurately specify the remote IP address of the connecting client, then malicious clients can spoof their IP address. This behavior does not necessarily constitute a security vulnerability, however some applications use client IP addresses to enforce access controls and rate limits. For example, an application might expose administrative functionality only to clients connecting from the local IP address of the server, or allow a certain number of failed login attempts from each unique IP address. Consider reviewing relevant functionality to determine whether this might be the case.

Issue remediation

HTTP request headers such as X-Forwarded-For, True-Client-IP, and X-Real-IP are not a robust foundation on which to build any security measures, such as access controls. Any such measures should be replaced with more secure alternatives that are not vulnerable to spoofing.

If the platform application server returns incorrect information about the client's IP address due to the presence of any particular HTTP request header, then the server may need to be reconfigured, or an alternative method of identifying clients should be used.

Vulnerability classifications

- CWE-16: Configuration

Request 1

```
GET / HTTP/1.1
Host: 10.185.200.36:8089
X-Forwarded-For: oqi7v6t9us82j1ckos631kpsejkc82wvujk6auz.oastify.com, 127.0.0.1
Pragma: no-cache
Cache-Control: no-cache, no-transform
Connection: close
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:50 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
Link: <http://10.185.200.36:8089/wp-json/wp/v2/pages/24>; rel="alternate"; title="JSON"; type="application/json"
Link: <http://10.185.200.36:8089/>; rel=shortlink
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Vary: Accept-Encoding
Connection: close
Content-Type: text/html; charset=UTF-8
Content-Length: 91313

<!doctype html>
<html lang="en-US">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1">
<link rel="profile" href="https://gmpg.org/xfn/11">

...[SNIP]...
```

Collaborator DNS interaction

The Collaborator server received a DNS lookup of type A for the domain name **oqi7v6t9us82j1ckos631kpsejkc82wvujk6auz.oastify.com**.

The lookup was received from IP address 103.21.127.65:51421 at 2026-Mar-11 06:20:50.159 UTC.

---

11. Input returned in response (reflected)

There are 7 instances of this issue:

- /comments/feed/ [name of an arbitrarily supplied URL parameter]
- /feed/ [name of an arbitrarily supplied URL parameter]
- /wp-admin/ [name of an arbitrarily supplied URL parameter]
- /wp-login.php [log parameter]
- /wp-login.php [redirect_to parameter]
- /wp-login.php [redirect_to parameter]
- /wp-login.php [user_login parameter]

Issue background

Reflection of input arises when data is copied from a request and echoed into the application's immediate response.

Input being returned in application responses is not a vulnerability in its own right. However, it is a prerequisite for many client-side vulnerabilities, including cross-site scripting, open redirection, content spoofing, and response header injection. Additionally, some server-side vulnerabilities such as SQL injection are often easier to identify and exploit when input is returned in responses. In applications where input retrieval is rare and the environment is resistant to automated testing (for example, due to a web application firewall), it might be worth subjecting instances of it to focused manual testing.

Vulnerability classifications

- CWE-20: Improper Input Validation
- CWE-116: Improper Encoding or Escaping of Output

11.1. http://10.185.200.36:8089/comments/feed/ [name of an arbitrarily supplied URL parameter]

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/comments/feed/**

Issue detail

The name of an arbitrarily supplied URL parameter is copied into the application's response.

Request 1

```
GET /comments/feed/?j946cbrouz=1 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:22 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Last-Modified: Fri, 06 Mar 2026 05:20:08 GMT
ETag: "462f0b134343aab79449d2f34fb97f7f-gzip"
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Vary: Accept-Encoding
Content-Length: 770
Connection: close
Content-Type: application/rss+xml; charset=UTF-8

<?xml version="1.0" encoding="UTF-8"?><rss version="2.0"
  xmlns:content="http://purl.org/rss/1.0/modules/content/"
  xmlns:dc="http://purl.org/dc/elements/1.1/"
  xmlns:atom="http://www.w3.org/2005/Atom
...[SNIP]...
<atom:link href="http://10.185.200.36:8089/comments/feed/?j946cbrouz=1" rel="self" type="application/rss+xml" />
```

...[SNIP]...

11.2. http://10.185.200.36:8089/feed/ [name of an arbitrarily supplied URL parameter]

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/feed/**

Issue detail

The name of an arbitrarily supplied URL parameter is copied into the application's response.

Request 1

```
GET /feed/?o811khg209=1 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:21:21 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Last-Modified: Fri, 06 Mar 2026 05:20:08 GMT
ETag: "462f0b134343aab79449d2f34fb97f7f-gzip"
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Vary: Accept-Encoding
Content-Length: 1136
Connection: close
Content-Type: application/rss+xml; charset=UTF-8

<?xml version="1.0" encoding="UTF-8"?><rss version="2.0"
  xmlns:content="http://purl.org/rss/1.0/modules/content/"
  xmlns:wfw="http://wellformedweb.org/CommentAPI/"
```

```
  xmlns:dc="http://purl.org/dc/eleme
...[SNIP]...
<atom:link href="http://10.185.200.36:8089/feed/?o811khg209=1" rel="self" type="application/rss+xml" />
...[SNIP]...
```

11.3. http://10.185.200.36:8089/wp-admin/ [name of an arbitrarily supplied URL parameter]

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-admin/**

Issue detail

The name of an arbitrarily supplied URL parameter is copied into the application's response.

Request 1

```
GET /wp-admin/?vo5zoc83mk=1 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:13 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self';
Referrer-Policy: strict-origin-when-cross-origin
Set-Cookie: wordpress_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-
Age=0; path=/wp-admin
Set-Cookie: wordpress_sec_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT;
Max-Age=0; path=/wp-admin
Set-Cookie: wordpress_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-
Age=0; path=/wp-content/plugins
```

```
Set-Cookie: wordpress_sec_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/wp-content/plugins
Set-Cookie: wordpress_logged_in_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Set-Cookie: wordpress_logged_in_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Set-Cookie: wp-settings-0=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Set-Cookie: wp-settings-time-0=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Set-Cookie: wordpress_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Set-Cookie: wordpress_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Set-Cookie: wordpress_sec_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Set-Cookie: wordpress_sec_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Set-Cookie: wordpressuser_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Set-Cookie: wordpresspass_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Set-Cookie: wordpressuser_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Set-Cookie: wordpresspass_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Set-Cookie: wp-postpass_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:13 GMT; Max-Age=0; path=/
Vary: Accept-Encoding
Content-Length: 8618
Connection: close
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
  <html lang="en-US">
  <head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Log In &lsaquo; Centre For Traditional Indian Knowledge and Skills &#8212; W
...[SNIP]...
<input type="hidden" name="redirect_to" value="http://10.185.200.36:8089/wp-admin/?vo5zoc83mk=1" />
...[SNIP]...
```

11.4. http://10.185.200.36:8089/wp-login.php [log parameter]

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-login.php**

Issue detail

The value of the **log** request parameter is copied into the application's response.

Request 1

```
POST /wp-login.php HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
```

```
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/wp-login.php?redirect_to=http%3A%2F%2F10.185.200.36%3A8089%2Fwp-
admin%2F&reauth=1
Content-Type: application/x-www-form-urlencoded
Content-Length: 140
Cookie: wordpress_test_cookie=WP%20Cookie%20check

log=YTxFlYoJtdo0t80ppv&pwd=u9Y%21p7x%21R8&rememberme=forever&wp-
submit=Log+In&redirect_to=http%3a%2f%2f10.185.200.36%3a8089%2fwp-admin%2f&testcookie=1
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:23 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self';
Referrer-Policy: strict-origin-when-cross-origin
Vary: Accept-Encoding
Content-Length: 9007
Connection: close
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
  <html lang="en-US">
  <head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Log In &lsaquo; Centre For Traditional Indian Knowledge and Skills &#8212; W
...[SNIP]...
<strong>YTxFlYoJtdo0t80ppv</strong>
...[SNIP]...
```

11.5. http://10.185.200.36:8089/wp-login.php [redirect_to parameter]

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-login.php**

Issue detail

The value of the **redirect_to** request parameter is copied into the application's response.

Request 1

```
POST /wp-login.php?action=lostpassword HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/wp-login.php?action=lostpassword
Content-Type: application/x-www-form-urlencoded
Content-Length: 57
Cookie: wordpress_test_cookie=WP%20Cookie%20check

user_login=PNpkec&redirect_to=vxfg6975xr&wp-submit=Get+New+Password
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:54 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self';
Referrer-Policy: strict-origin-when-cross-origin
Vary: Accept-Encoding
Content-Length: 5638
Connection: close
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
  <html lang="en-US">
  <head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Lost Password &lsaquo; Centre For Traditional Indian Knowledge and Skills &#
...[SNIP]...
<input type="hidden" name="redirect_to" value="vxfg6975xr" />
...[SNIP]...
```

11.6. http://10.185.200.36:8089/wp-login.php [redirect_to parameter]

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**

Path: **/wp-login.php**

Issue detail

The value of the **redirect_to** request parameter is copied into the application's response.

Request 1

```
GET /wp-login.php?redirect_to=http%3a%2f%2f10.185.200.36%3a8089%2fwp-admin%2f0txz5rr1oj&reauth=1 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/wp-admin/
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:12 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self';
Referrer-Policy: strict-origin-when-cross-origin
Set-Cookie: wordpress_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT; Max-
Age=0; path=/wp-admin
Set-Cookie: wordpress_sec_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT;
Max-Age=0; path=/wp-admin
Set-Cookie: wordpress_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT; Max-
Age=0; path=/wp-content/plugins
Set-Cookie: wordpress_sec_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT;
Max-Age=0; path=/wp-content/plugins
Set-Cookie: wordpress_logged_in_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12
GMT; Max-Age=0; path=/
Set-Cookie: wordpress_logged_in_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12
GMT; Max-Age=0; path=/
Set-Cookie: wp-settings-0=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT; Max-Age=0; path=/
Set-Cookie: wp-settings-time-0=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT; Max-Age=0; path=/
Set-Cookie: wordpress_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT; Max-
Age=0; path=/
Set-Cookie: wordpress_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT; Max-
Age=0; path=/
Set-Cookie: wordpress_sec_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT;
Max-Age=0; path=/
Set-Cookie: wordpress_sec_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT;
Max-Age=0; path=/
Set-Cookie: wordpressuser_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT; Max-
Age=0; path=/
Set-Cookie: wordpresspass_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT;
Max-Age=0; path=/
```

```
Set-Cookie: wordpressuser_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT; Max-Age=0; path=/
Set-Cookie: wordpresspass_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT; Max-Age=0; path=/
Set-Cookie: wp-postpass_64dca68099eddcea05f5370603b6d091=%20; expires=Tue, 11 Mar 2025 06:20:12 GMT; Max-Age=0; path=/
Vary: Accept-Encoding
Content-Length: 8615
Connection: close
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
  <html lang="en-US">
  <head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Log In &lsaquo; Centre For Traditional Indian Knowledge and Skills &#8212; W
...[SNIP]...
<input type="hidden" name="redirect_to" value="http://10.185.200.36:8089/wp-admin/0txz5rr1oj" />
...[SNIP]...
```

11.7. http://10.185.200.36:8089/wp-login.php [user_login parameter]

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-login.php**

Issue detail

The value of the **user_login** request parameter is copied into the application's response.

Request 1

```
POST /wp-login.php?action=lostpassword HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/wp-login.php?action=lostpassword
Content-Type: application/x-www-form-urlencoded
Content-Length: 11
Cookie: wordpress_test_cookie=WP%20Cookie%20check

user_login=8h32o3y5zb
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:29 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self';
Referrer-Policy: strict-origin-when-cross-origin
Vary: Accept-Encoding
Content-Length: 5632
Connection: close
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
  <html lang="en-US">
  <head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Lost Password &lsaquo; Centre For Traditional Indian Knowledge and Skills &#
...[SNIP]...
<input type="text" name="user_login" id="user_login" class="input" value="8h32o3y5zb" size="20" autocapitalize="off"
autocomplete="username" required="required" />
...[SNIP]...
```

---

12. Cross-domain Referer leakage

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-login.php**

Issue detail

The page was loaded from a URL containing a query string:

- http://10.185.200.36:8089/wp-login.php

The response contains the following link to another domain:

- https://wordpress.org/

Issue background

When a web browser makes a request for a resource, it typically adds an HTTP header, called the "Referer" header, indicating the URL of the resource from which the request originated. This occurs in numerous situations, for example when a web page loads an image or script, or when a user clicks on a link or submits a form.

If the resource being requested resides on a different domain, then the Referer header is still generally included in the cross-domain request. If the originating URL contains any sensitive information within its query string, such as a session token, then this information will be transmitted to the other domain. If the other domain is not fully trusted by the application, then this may lead to a security compromise.

You should review the contents of the information being transmitted to other domains, and also determine whether those domains are fully trusted by the originating application.

Today's browsers may withhold the Referer header in some situations (for example, when loading a non-HTTPS resource from a page that was loaded over HTTPS, or when a Refresh directive is issued), but this behavior should not be relied upon to protect the originating URL from disclosure.

Note also that if users can author content within the application then an attacker may be able to inject links referring to a domain they control in order to capture data from URLs used within the application.

Issue remediation

Applications should never transmit any sensitive information within the URL query string. In addition to being leaked in the Referer header, such information may be logged in various locations and may be visible on-screen to untrusted parties. If placing sensitive information in the URL is unavoidable, consider using the Referer-Policy HTTP header to reduce the chance of it being disclosed to third parties.

References

- Referer Policy
- Web Security Academy: Information disclosure

Vulnerability classifications

- CWE-200: Information Exposure

Request 1

```
POST /wp-login.php?action=lostpassword HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/wp-login.php?action=lostpassword
Content-Type: application/x-www-form-urlencoded
Content-Length: 11
Cookie: wordpress_test_cookie=WP%20Cookie%20check

user_login=
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:14 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self';
Referrer-Policy: strict-origin-when-cross-origin
Vary: Accept-Encoding
Content-Length: 5607
Connection: close
Content-Type: text/html; charset=UTF-8
```

```
<!DOCTYPE html>
  <html lang="en-US">
  <head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Lost Password &lsaquo; Centre For Traditional Indian Knowledge and Skills &#
...[SNIP]...
<h1 role="presentation" class="wp-login-logo"><a href="https://wordpress.org/">Powered by WordPress</a>
...[SNIP]...
```

---

13. Frameable response (potential Clickjacking)

Summary

Severity:	**Information**
Confidence:	**Firm**
Host:	**http://10.185.200.36:8089**
Path:	**/**

Issue detail

This issue was found in multiple locations under the reported path.

Issue background

If a page fails to set an appropriate X-Frame-Options or Content-Security-Policy HTTP header, it might be possible for a page controlled by an attacker to load it within an iframe. This may enable a clickjacking attack, in which the attacker's page overlays the target application's interface with a different interface provided by the attacker. By inducing victim users to perform actions such as mouse clicks and keystrokes, the attacker can cause them to unwittingly carry out actions within the application that is being targeted. This technique allows the attacker to circumvent defenses against cross-site request forgery, and may result in unauthorized actions.

Note that some applications attempt to prevent these attacks from within the HTML page itself, using "framebusting" code. However, this type of defense is normally ineffective and can usually be circumvented by a skilled attacker.

You should determine whether any functions accessible within frameable pages can be used by application users to perform any sensitive actions within the application.

Issue remediation

To effectively prevent framing attacks, the application should return a response header with the name **X-Frame-Options** and the value **DENY** to prevent framing altogether, or the value **SAMEORIGIN** to allow framing only by pages on the same origin as the response itself. Note that the SAMEORIGIN header can be partially bypassed if the application itself can be made to frame untrusted websites.

References

- Web Security Academy: Clickjacking
- X-Frame-Options

Vulnerability classifications

- CWE-693: Protection Mechanism Failure
- CWE-1021: Improper Restriction of Rendered UI Layers or Frames
- CAPEC-103: Clickjacking

Request 1

```
GET / HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:06 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
Link: <http://10.185.200.36:8089/wp-json/wp/v2/pages/24>; rel="alternate"; title="JSON"; type="application/json"
Link: <http://10.185.200.36:8089/>; rel=shortlink
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Vary: Accept-Encoding
Content-Length: 91313
Connection: close
Content-Type: text/html; charset=UTF-8

<!doctype html>
<html lang="en-US">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1">
<link rel="profile" href="https://gmpg.org/xfn/11">

...[SNIP]...
```

Request 2

```
GET /about-us/ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
```

Response 2

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:08 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
Link: <http://10.185.200.36:8089/wp-json/wp/v2/pages/14>; rel="alternate"; title="JSON"; type="application/json"
Link: <http://10.185.200.36:8089/?p=14>; rel=shortlink
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Vary: Accept-Encoding
Content-Length: 79391
Connection: close
Content-Type: text/html; charset=UTF-8

<!doctype html>
<html lang="en-US">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1">
<link rel="profile" href="https://gmpg.org/xfn/11">

...[SNIP]...
```

Request 3

```
GET /people/ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
```

Response 3

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:08 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
Link: <http://10.185.200.36:8089/wp-json/wp/v2/pages/16>; rel="alternate"; title="JSON"; type="application/json"
Link: <http://10.185.200.36:8089/?p=16>; rel=shortlink
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Vary: Accept-Encoding
Content-Length: 78558
Connection: close
Content-Type: text/html; charset=UTF-8
```

```
<!doctype html>
<html lang="en-US">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1">
<link rel="profile" href="https://gmpg.org/xfn/11">

...[SNIP]...
```

14. Backup file

There are 5 instances of this issue:

- /academics~
- /author/25m1522~
- /langtech~
- /news~
- /watermgmt~

Issue description

Publicly accessible backups and outdated copies of files can provide attackers with extra attack surface. Depending on the server configuration and file type, they may also expose source code, configuration details, and other information intended to remain secret.

Issue remediation

Review the file to identify whether it's intended to be publicly accessible, and remove it from the server's web root if it isn't. It may also be worth auditing the server contents to find other outdated files, and taking measures to prevent the problem from reoccurring.

References

- Web Security Academy: Information disclosure via backup files

Vulnerability classifications

- CWE-530: Exposure of Backup File to an Unauthorized Control Sphere
- CAPEC-37: Retrieve Embedded Sensitive Data
- CAPEC-204: Lifting Sensitive Data Embedded in Cache

14.1. http://10.185.200.36:8089/academics~

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/academics/**

Request 1

```
GET /academics~ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
```

Response 1

```
HTTP/1.1 301 Moved Permanently
Date: Wed, 11 Mar 2026 06:21:15 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Redirect-By: WordPress
Location: http://10.185.200.36:8089/academics~/
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8
```

Request 2

```
GET /t~ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
```

Response 2

```
HTTP/1.1 404 Not Found
Date: Wed, 11 Mar 2026 06:21:15 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
```

```
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8
```

14.2. http://10.185.200.36:8089/author/25m1522~

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/author/25m1522/**

Request 1

```
GET /author/25m1522~ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/wp-json/oembed/1.0/embed?
url=http%3A%2F%2F10.185.200.36%3A8089%2F&format=xml
```

Response 1

```
HTTP/1.1 301 Moved Permanently
Date: Wed, 11 Mar 2026 06:23:56 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Redirect-By: WordPress
Location: http://10.185.200.36:8089/author/25m1522~/
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8
```

Request 2

```
GET /author/w~ HTTP/1.1
Host: 10.185.200.36:8089
```

```
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/wp-json/oembed/1.0/embed?
url=http%3A%2F%2F10.185.200.36%3A8089%2F&format=xml
```

Response 2

```
HTTP/1.1 404 Not Found
Date: Wed, 11 Mar 2026 06:23:56 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8
```

14.3. http://10.185.200.36:8089/langtech~

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/langtech/**

Request 1

```
GET /langtech~ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
```

```
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/research/
```

Response 1

```
HTTP/1.1 301 Moved Permanently
Date: Wed, 11 Mar 2026 06:21:23 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Redirect-By: WordPress
Location: http://10.185.200.36:8089/langtech~/
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8
```

Request 2

```
GET /x~ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/research/
```

Response 2

```
HTTP/1.1 404 Not Found
Date: Wed, 11 Mar 2026 06:21:23 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8
```

14.4. http://10.185.200.36:8089/news~

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/news/**

Request 1

```
GET /news~ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
```

Response 1

```
HTTP/1.1 301 Moved Permanently
Date: Wed, 11 Mar 2026 06:21:17 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Redirect-By: WordPress
Location: http://10.185.200.36:8089/news~/
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8
```

Request 2

```
GET /x~ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
```

Response 2

```
HTTP/1.1 404 Not Found
Date: Wed, 11 Mar 2026 06:21:17 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8
```

14.5. http://10.185.200.36:8089/watermgmt~

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/watermgmt/**

Request 1

```
GET /watermgmt~ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/watermgmt
```

Response 1

```
HTTP/1.1 301 Moved Permanently
Date: Wed, 11 Mar 2026 06:21:25 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Redirect-By: WordPress
Location: http://10.185.200.36:8089/watermgmt~/
Content-Length: 0
Connection: close
```

```
Content-Type: text/html; charset=UTF-8
```

Request 2

```
GET /u~ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/watermgmt
```

Response 2

```
HTTP/1.1 404 Not Found
Date: Wed, 11 Mar 2026 06:21:25 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8
```

---

15. Email addresses disclosed

There are 2 instances of this issue:

- /people/
- /wp-json/wp/v2/pages/16

Issue background

The presence of email addresses within application responses does not necessarily constitute a security vulnerability. Email addresses may appear intentionally within contact information, and many applications (such as web mail) include arbitrary third-party email addresses within their core content.

However, email addresses of developers and other individuals (whether appearing on-screen or hidden within page source) may disclose information that is useful to an attacker; for example, they may represent usernames that can be used at the application's login, and they may be used in social engineering attacks against the organization's personnel. Unnecessary or excessive disclosure of email addresses may also lead to an increase in the volume of spam email received.

Issue remediation

Consider removing any email addresses that are unnecessary, or replacing personal addresses with anonymous mailbox addresses (such as helpdesk@example.com).

To reduce the quantity of spam sent to anonymous mailbox addresses, consider hiding the email address and instead providing a form that generates the email server-side, protected by a CAPTCHA if necessary.

References

- Web Security Academy: Information disclosure

Vulnerability classifications

- CWE-200: Information Exposure
- CAPEC-37: Retrieve Embedded Sensitive Data

15.1. http://10.185.200.36:8089/people/

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/people/**

Issue detail

The following email address was disclosed in the response:

- pic.ctiks@iitb.ac.in

Request 1

```
GET /people/ HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:08 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
Link: <http://10.185.200.36:8089/wp-json/wp/v2/pages/16>; rel="alternate"; title="JSON"; type="application/json"
Link: <http://10.185.200.36:8089/?p=16>; rel=shortlink
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Vary: Accept-Encoding
Content-Length: 78558
Connection: close
Content-Type: text/html; charset=UTF-8

<!doctype html>
<html lang="en-US">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1">
<link rel="profile" href="https://gmpg.org/xfn/11">

...[SNIP]...
<a href="mailto:pic.ctiks@iitb.ac.in">
...[SNIP]...
```

15.2. http://10.185.200.36:8089/wp-json/wp/v2/pages/16

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages/16**

Issue detail

The following email address was disclosed in the response:

- pic.ctiks@iitb.ac.in

Request 1

```
GET /wp-json/wp/v2/pages/16 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
```

```
Referer: http://10.185.200.36:8089/people/
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:41 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/people/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 8114

{"id":16,"date":"2026-02-09T04:50:22","date_gmt":"2026-02-09T04:50:22","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=16"},"modified":"2026-03-06T05:20:08","modified_gmt":"2026-03-06T05:20:08","s
...[SNIP]...
<a href=\"mailto:pic.ctiks@iitb.ac.in\">
...[SNIP]...
```

---

16. Private IP addresses disclosed

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/wp-json/wp/v2/pages**

Issue detail

The following RFC 1918 IP address was disclosed in the response:

- 10.18.33.196

This issue was found in multiple locations under the reported path.

Issue background

RFC 1918 specifies ranges of IP addresses that are reserved for use in private networks and cannot be routed on the public Internet. Although various methods exist by which an attacker can determine the public IP addresses in use by an organization, the private addresses used internally cannot usually be determined in the same ways.

Discovering the private addresses used within an organization can help an attacker in carrying out network-layer attacks aiming to penetrate the organization's internal infrastructure.

Issue remediation

There is not usually any good reason to disclose the internal IP addresses used within an organization's infrastructure. If these are being returned in service banners or debug messages, then the relevant services should be configured to mask the private addresses. If they are being used to track back-end servers for load balancing purposes, then the addresses

should be rewritten with innocuous identifiers from which an attacker cannot infer any useful information about the infrastructure.

References

- Web Security Academy: Information disclosure

Vulnerability classifications

- CWE-200: Information Exposure
- CAPEC-37: Retrieve Embedded Sensitive Data

Request 1

```
GET /wp-json/wp/v2/pages/24 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:29 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 21779

{"id":24,"date":"2026-02-09T04:51:38","date_gmt":"2026-02-09T04:51:38","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=24"},"modified":"2026-03-04T11:46:44","modified_gmt":"2026-03-04T11:46:44","slug":"home","status":"publish","typ
e":"page","link":"http:\/\/10.185.200.36:8089\/","title":{"rendered":"Home"},"
...[SNIP]...
```

Request 2

```
GET /wp-json/wp/v2/pages/14 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
```

```
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/about-us/
```

Response 2

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:40 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/about-us/>; rel="alternate"; type=text/html
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Vary: Origin
Connection: close
Content-Type: application/json; charset=UTF-8
Content-Length: 9328

{"id":14,"date":"2026-02-09T04:49:48","date_gmt":"2026-02-09T04:49:48","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=14"},"modified":"2026-03-06T05:15:49","modified_gmt":"2026-03-06T05:15:49","slug":"about-
us","status":"publish","type":"page","link":"http:\/\/10.185.200.36:8089\/about-us\/","title":{"rende
...[SNIP]...
```

Request 3

```
GET /wp-json/wp/v2/pages/26 HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://10.185.200.36:8089/research/
```

Response 3

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:45 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
X-Robots-Tag: noindex
Link: <http://10.185.200.36:8089/research/>; rel="alternate"; type=text/html
```

```
X-Content-Type-Options: nosniff
Access-Control-Expose-Headers: X-WP-Total, X-WP-TotalPages, Link
Access-Control-Allow-Headers: Authorization, X-WP-Nonce, Content-Disposition, Content-MD5, Content-Type
Allow: GET
Vary: Origin
Content-Length: 5156
Connection: close
Content-Type: application/json; charset=UTF-8

{"id":26,"date":"2026-02-09T04:52:26","date_gmt":"2026-02-09T04:52:26","guid":{"rendered":"http:\/\/10.18.33.196\/?
page_id=26"},"modified":"2026-03-04T11:53:38","modified_gmt":"2026-03-04T11:53:38","slug":"research","status":"publish","
type":"page","link":"http:\/\/10.185.200.36:8089\/research\/","title":{"rende
...[SNIP]...
```

---

17. Robots.txt file

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**http://10.185.200.36:8089**
Path:	**/robots.txt**

Issue detail

The web server contains a robots.txt file.

Issue background

The file robots.txt is used to give instructions to web robots, such as search engine crawlers, about locations within the web site that robots are allowed, or not allowed, to crawl and index.

The presence of the robots.txt does not in itself present any kind of security vulnerability. However, it is often used to identify restricted or private areas of a site's contents. The information in the file may therefore help an attacker to map out the site's contents, especially if some of the locations identified are not linked from elsewhere in the site. If the application relies on robots.txt to protect access to these areas, and does not enforce proper access control over them, then this presents a serious vulnerability.

Issue remediation

The robots.txt file is not itself a security threat, and its correct use can represent good practice for non-security reasons. You should not assume that all web robots will honor the file's instructions. Rather, assume that attackers will pay close attention to any locations identified in the file. Do not rely on robots.txt to provide any kind of protection over unauthorized access.

Vulnerability classifications

- CWE-200: Information Exposure

Request 1

```
GET /robots.txt HTTP/1.1
Host: 10.185.200.36:8089
Cache-Control: max-age=0
Sec-Ch-Ua: "Google Chrome";v="145", "Not=A?Brand";v="8", "Chromium";v="145"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
```

```
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/
*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
```

Response 1

```
HTTP/1.1 200 OK
Date: Wed, 11 Mar 2026 06:20:07 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: PHP/8.4.18
Link: <http://10.185.200.36:8089/wp-json/>; rel="https://api.w.org/"
X-TEC-API-VERSION: v1
X-TEC-API-ROOT: http://10.185.200.36:8089/wp-json/tribe/events/v1/
X-TEC-API-ORIGIN: http://10.185.200.36:8089
Content-Length: 67
Connection: close
Content-Type: text/plain; charset=utf-8

User-agent: *
Disallow: /wp-admin/
Allow: /wp-admin/admin-ajax.php
```

Report generated by Burp Suite web vulnerability scanner v2026.2.3, at Wed Mar 11 11:56:39 IST 2026.